

Exercício 4 — Calcular CVSS

Cenário: Uma vulnerabilidade de execução remota de código em um servidor web amplamente utilizado. O invasor pode executar código arbitrário remotamente sem necessidade de autenticação.

Identifique as métricas base, calcule a pontuação CVSS v3.1, discuta as implicações e recomende estratégias de mitigação.

4. Calcular CVSS

Cenário de Vulnerabilidade

*Vulnerabilidade de execução remota de código em um servidor web amplamente utilizado. O invasor pode executar qualquer código remotamente — **sem necessidade de autenticação**.*

Passo 1 — Identificar as Métricas Base

Métrica	Valor	Justificativa
Vetor de Ataque (AV)	Rede	Explorado remotamente pela internet
Complexidade do Ataque (AC)	Baixa	Nenhuma condição especial necessária
Privilegios Necessários (PR)	Nenhum	Sem necessidade de autenticação
Interação do Usuário (UI)	Nenhuma	O invasor age sozinho, sem necessidade de clique da vítima

Métrica	Valor	Justificativa
Escopo (S)	Inalterado	O ataque permanece dentro do servidor web
Confidencialidade (C)	Alto	O invasor pode ler qualquer dado no servidor
Integridade (I)	Alto	O invasor pode modificar ou excluir qualquer dado
Disponibilidade (A)	Alto	O invasor pode derrubar ou desabilitar o servidor

Nota: O exercício lista PR como "Necessário" e UI como "Necessária" — mas o cenário afirma claramente sem necessidade de autenticação, então os valores corretos são **Nenhum** para ambos.

Passo 2 — Calcular a Pontuação Base (CVSS v3.1)

ISCBASE (impacto da vulnerabilidade):

$$\begin{aligned}
 \text{ISCBASE} &= 1 - [(1 - 0,56) \times (1 - 0,56) \times (1 - 0,56)] \\
 &= 1 - [0,44 \times 0,44 \times 0,44] \\
 &= 1 - 0,0852 \\
 &= 0,9148
 \end{aligned}$$

ISC (Escopo = Inalterado):

$$\text{ISC} = 6,42 \times 0,9148 = 5,87$$

Explorabilidade (facilidade de exploração):

$$\begin{aligned}
 \text{Explorabilidade} &= 8,22 \times 0,85 \times 0,77 \times 0,85 \times 0,85 \\
 &= 8,22 \times 0,4737 \\
 &= 3,89
 \end{aligned}$$

Pontuação Final:

```
Pontuação CVSS = Arredondamento(Mín[(5,87 + 3,89), 10])  
                = Arredondamento(9,76)  
                = 9,8
```

Passo 3 — Resultado

Pontuação CVSS	9,8
Severidade	Crítico
Vetor CVSS	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

*Este é um dos piores perfis possíveis. Um exemplo real com este perfil é o **Log4Shell (CVE-2021-44228)**, que recebeu pontuação 10.0.*

Passo 4 — Implicações para a Organização

- Qualquer invasor na internet pode explorar isso sem habilidades especiais (AC: Baixa, PR: Nenhum).
- Controle total sobre o servidor significa que **roubo de dados, ransomware e movimentação lateral** são todos possíveis.
- Por afetar um servidor web *amplamente utilizado*, milhares de organizações podem estar expostas simultaneamente.
- Impacto regulatório: uma violação pode acionar penalidades sob **LGPD, GDPR, HIPAA ou PCI-DSS**.

Passo 5 — Estratégias de Mitigação

Imediato (24-72 horas)

- Aplicar o patch do fornecedor como **atualização emergencial** — não aguardar a próxima janela de manutenção.
- Se não houver patch disponível, **desabilitar ou isolar** o serviço afetado imediatamente.
- Bloquear tentativas de exploração no nível do **WAF (Firewall de Aplicação Web)** como solução temporária.

Curto prazo (dentro de 1 semana)

- Escanear todo o ambiente em busca de outras instâncias do mesmo software.
- Verificar logs em busca de sinais de exploração **antes** da aplicação do patch.
- Rotacionar credenciais ou segredos que possam ter sido expostos no servidor afetado.

Longo prazo

- Adotar um programa de **varredura contínua de vulnerabilidades** (Nessus, Qualys, OpenVAS).
- Monitorar o **CISA KEV** para identificar CVEs ativamente explorados antecipadamente.
- Aplicar o **princípio do menor privilégio** para limitar o impacto em caso de comprometimento.